

Министерство образования Республики Беларусь

Учреждение образования
БЕЛОРУССКИЙ ГОСУДАРСТВЕННЫЙ УНИВЕРСИТЕТ
ИНФОРМАТИКИ И РАДИОЭЛЕКТРОНИКИ

Факультет информационных технологий и управления
Кафедра интеллектуальных информационных технологий

Отчет
к лабораторной работе №2.1
по дисциплине "Проектирование защищенных интеллектуальных
информационных систем"
на тему:

**АНАЛИЗ БЕЗОПАСНОСТИ КОДА
РАЗРАБАТЫВАЕМОГО ПРИЛОЖЕНИЯ**

Студент гр. 121702
Руководитель

Д. С. Голушко
В. В. Захаров

Минск 2024 г.

СОДЕРЖАНИЕ

1	Ход работы	6
1.1	Скриншоты выполнения задания	6
1.2	Анализ разработанного приложения	12
1.2.1	Политика безопасности операционной системы	12
1.2.2	Политика безопасности компонентов приложения и их взаимодействие между собой	12
1.2.3	Сетевая политика безопасности	13
1.2.4	Безопасность конфиденциальности данных	13
1.2.5	Вывод	13
	Вывод	14
	Список использованных источников	14

1 ХОД РАБОТЫ

Постановка задачи: Разработать приложение, которое позволяет:

- добавить пользователя в систему,
- авторизовать пользователя на основе идентификационных данных,
- создать, редактировать, удалить, осуществить поиск конфиденциальных данных,
- создать, редактировать, удалить, осуществить поиск неконфиденциальных данных

Также необходимо выполнить анализ разработанного приложения с точки зрения:

- политики безопасности операционной системы,
- политики безопасности компонентов приложения и их взаимодействия между собой,
- сетевой политики безопасности,
- безопасности конфиденциальности данных.

1.1 Скриншоты выполнения задания

1. Вход под записью администратора, создание новой базы данных;

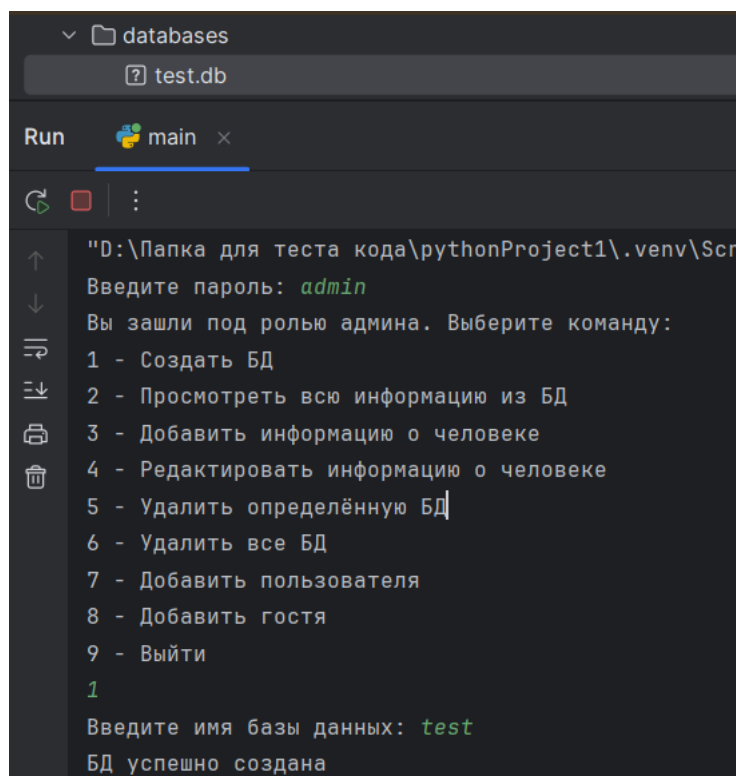


Рисунок 1.1 – Изображение входа и создания базы данных

2. Проверка базы после создания;

```
Введите пароль: admin
Вы зашли под ролью админа. Выберите команду:
1 - Создать БД
2 - Просмотреть всю информацию из БД
3 - Добавить информацию о человеке
4 - Редактировать информацию о человеке
5 - Удалить определённую БД
6 - Удалить все БД
7 - Добавить пользователя
8 - Добавить гостя
9 - Выйти
2
Введите имя базы данных: test
База данных пуста.
```

Рисунок 1.2 – Изображение проверки базы после создания

3. Добавление нового гостя;

```
Введите пароль: admin
Вы зашли под ролью админа. Выберите команду:
1 - Создать БД
2 - Просмотреть всю информацию из БД
3 - Добавить информацию о человеке
4 - Редактировать информацию о человеке
5 - Удалить определённую БД
6 - Удалить все БД
7 - Добавить пользователя
8 - Добавить гостя
9 - Выйти
8
Введите имя нового пользователя: new
Гость new успешно добавлен.
```

Рисунок 1.3 – Изображение добавления нового гостя

4. Создание записи в базе данных;

```
Введите пароль: admin
Вы зашли под ролью админа. Выберите команду:
1 - Создать БД
2 - Просмотреть всю информацию из БД
3 - Добавить информацию о человеке
4 - Редактировать информацию о человеке
5 - Удалить определённую БД
6 - Удалить все БД
7 - Добавить пользователя
8 - Добавить гостя
9 - Выйти
3
Введите имя базы данных: test
Введите имя человека: САШКА ПИПКО
Введите возраст человека: 20
Введите зарплату человека: -1000
Информация о человеке добавлена успешно
```

Рисунок 1.4 – Изображение создания записи в базе данных

5. Просмотр базы данных;

```
Введите пароль: admin
Вы зашли под ролью админа. Выберите команду:
1 - Создать БД
2 - Просмотреть всю информацию из БД
3 - Добавить информацию о человеке
4 - Редактировать информацию о человеке
5 - Удалить определённую БД
6 - Удалить все БД
7 - Добавить пользователя
8 - Добавить гостя
9 - Выйти
2
Введите имя базы данных: test
Вся информация из БД:
(1, 'САШКА ПИПКО', 20, -1000)
```

Рисунок 1.5 – Изображение просмотра базы данных

6. Создание нового пользователя;

```
Вы зашли под ролью админа. Выберите команду:  
1 - Создать БД  
2 - Просмотреть всю информацию из БД  
3 - Добавить информацию о человеке  
4 - Редактировать информацию о человеке  
5 - Удалить определённую БД  
6 - Удалить все БД  
7 - Добавить пользователя  
8 - Добавить гостя  
9 - Выйти  
7  
Введите имя пользователя: sashs  
Введите пароль пользователя: 1234  
Пользователь sashs успешно добавлен.
```

Рисунок 1.6 – Изображение создания нового пользователя

7. Добавление записи в базу данных пользователем;

```
Введите пароль: 1234  
Вы зашли как обычный пользователь. Выберите команду:  
1 - Просмотреть всю информацию из БД  
2 - Добавить информацию о человеке  
3 - Редактировать информацию о человеке  
4 - Выйти  
2  
Введите имя базы данных: test  
Введите имя человека: NIKITA  
Введите возраст человека: 20  
Введите зарплату человека: 1000
```

Рисунок 1.7 – Изображение добавление записи в базу данных пользователем

8. Просмотр базы данных после действий пользователя;

```
Введите пароль: 1234
Вы зашли как обычный пользователь. Выберите команду:
1 - Просмотреть всю информацию из БД
2 - Добавить информацию о человеке
3 - Редактировать информацию о человеке
4 - Выйти
1
Введите имя базы данных: test
Вся информация из БД:
(1, 'САШКА ПИПКО', 20, -1000)
(2, 'НИКИТА', 20, 1000)
```

Рисунок 1.8 – Изображение просмотра базы данных после действий пользователя

9. Просмотр информации от записи гостя;

```
Введите пароль или логин гостя: guest
Вы зашли как гость. Выберите команду:
1 - Просмотреть информацию из БД
2 - Выйти
1
Введите имя базы данных: test
Вся информация из БД:
('САШКА ПИПКО',)
('НИКИТА',)
```

Рисунок 1.9 – Изображение просмотра информации от записи гостя

10. Обновление информации от записи администратора;

```
Введите пароль или логин гостя: admin
Вы зашли под ролью админа. Выберите команду:
1 - Создать БД
2 - Просмотреть всю информацию из БД
3 - Добавить информацию о человеке
4 - Редактировать информацию о человеке
5 - Удалить определённую БД
6 - Удалить все БД
7 - Добавить пользователя
8 - Добавить гостя
9 - Выйти
4
Введите имя базы данных: test
Введите ID человека для редактирования: 1
Текущая информация: ID=1, Имя=САШКА ПИПКО, Возраст=20, Зарплата=-1000
Введите новое имя (оставьте пустым, чтобы не изменять): ALEX
Введите новый возраст (оставьте пустым, чтобы не изменять): 25
Введите новую зарплату (оставьте пустым, чтобы не изменять): 1234
Информация о человеке с ID=1 успешно обновлена.
```

Рисунок 1.10 – Изображение обновления информации

11. Просмотр базы после изменений;

```
Введите пароль или логин гостя: admin
Вы зашли под ролью админа. Выберите команду:
1 - Создать БД
2 - Просмотреть всю информацию из БД
3 - Добавить информацию о человеке
4 - Редактировать информацию о человеке
5 - Удалить определённую БД
6 - Удалить все БД
7 - Добавить пользователя
8 - Добавить гостя
9 - Выйти
2
Введите имя базы данных: test
Вся информация из БД:
(1, 'ALEX', 25, 1234)
(2, 'NIKITA', 20, 1000)
```

Рисунок 1.11 – Изображение просмотра базы после изменений

1.2 Анализ разработанного приложения

Выполним анализ приложения в соответствии с требованиями лабораторной работы

1.2.1 Политика безопасности операционной системы

Работа с файлами: Приложение использует файловую систему для работы с базами данных и JSON-файлами. Файлы базы данных и конфиденциальные данные пользователей хранятся в локальных файлах. Важно, чтобы на уровне операционной системы были настроены правильные права доступа к этим файлам (чтение/запись только для администратора), чтобы предотвратить несанкционированный доступ.

При условии, что права доступа к файлам правильно настроены, и никто, кроме администратора, не имеет доступа к этим ресурсам, приложение будет надежно защищено от угроз, связанных с несанкционированным доступом.

Работа с процессами и доступ к системным ресурсам: Приложение не использует системные ресурсы интенсивно, а также не запускает внешние процессы, что минимизирует риски эксплуатации на уровне ОС. Также оно не требует повышения привилегий, что снижает вероятность нарушения безопасности на уровне прав доступа.

Приложение работает в рамках стандартных пользовательских привилегий, что ограничивает возможность эксплуатации уязвимостей на уровне операционной системы.

1.2.2 Политика безопасности компонентов приложения и их взаимодействие между собой

Аутентификация пользователей: Приложение поддерживает несколько уровней пользователей (администратор, обычный пользователь, гость). Аутентификация осуществляется через ввод пароля. Данные пользователей хранятся в JSON-файлах, что упрощает управление ими. Административные функции защищены паролем, и обычные пользователи не могут получить доступ к административным функциям, что укрепляет безопасность.

Правильная разграниченность прав доступа для разных уровней пользователей, а также наличие аутентификации на каждом уровне обеспечивает безопасное взаимодействие компонентов приложения.

Изоляция баз данных: Приложение изолирует базы данных для каждого запроса, используя отдельные файлы. Это снижает риск утечки данных между различными базами. При этом манипуляции с базами данных доступны только авторизованным пользователям.

Изоляция данных и контроль доступа к базе данных усиливают безопасность и гарантируют, что данные остаются конфиденциальными и защищенными от посторонних.

1.2.3 Сетевая политика безопасности

Отсутствие сетевых подключений: Приложение работает в локальной среде и не требует подключения к сети для выполнения основных функций. Это устраняет многие риски, связанные с сетевой безопасностью, такие как атаки через сеть, утечки данных через интернет и т. д.

Отсутствие сетевых взаимодействий исключает сетевые атаки и снижает уязвимость к внешним угрозам.

1.2.4 Безопасность конфиденциальности данных

Хранение данных: Приложение хранит данные пользователей и гостей в JSON-файлах. Для администраторов и пользователей информация защищена через механизм аутентификации паролями. Уровень конфиденциальности данных напрямую зависит от безопасности файловой системы.

Минимизация утечки данных: Приложение предоставляет гостям ограниченный доступ только к именам людей, исключая возможность просмотра конфиденциальной информации о них (например, зарплата или возраста).

Хранение данных в изолированных JSON-файлах и ограничение прав доступа для различных ролей обеспечивает высокий уровень конфиденциальности и защиты данных пользователей.

1.2.5 Вывод

При правильной настройке операционной системы (особенно прав доступа к файлам) и организации контролируемого доступа на уровне приложения, текущая реализация обладает хорошей базовой безопасностью. Благодаря отсутствию сетевых подключений и четкому разграничению прав пользователей приложение может считаться безопасным с точки зрения управления данными и конфиденциальности.

ВЫВОД

В ходе выполнения лабораторной работы были выполнены все поставленные задания: создана программа, позволяющая работать с пользователями и выполнять различные операции с конфиденциальными и неконфиденциальными данными. Также выполнен анализ приложения с точек зрения безопасности операционной системы, работы с данными, сетевой политики и работы компонентов между собой.